

The Swiss Cheese of SaaS Identity Security

CypherCon 2026



whoami



Eric Woodruff



**Chief Identity Architect
Microsoft Security MVP
IDPro Certified Identity Professional (CIDPRO)**



@ericonidentity.com



@ericonidentity



/in/ericonidentity



@ericonidentity@infosec.exchange

Agenda

- The problem
- Tenant administration abuses
- Developer derived abuses
- Vendor derived abuses

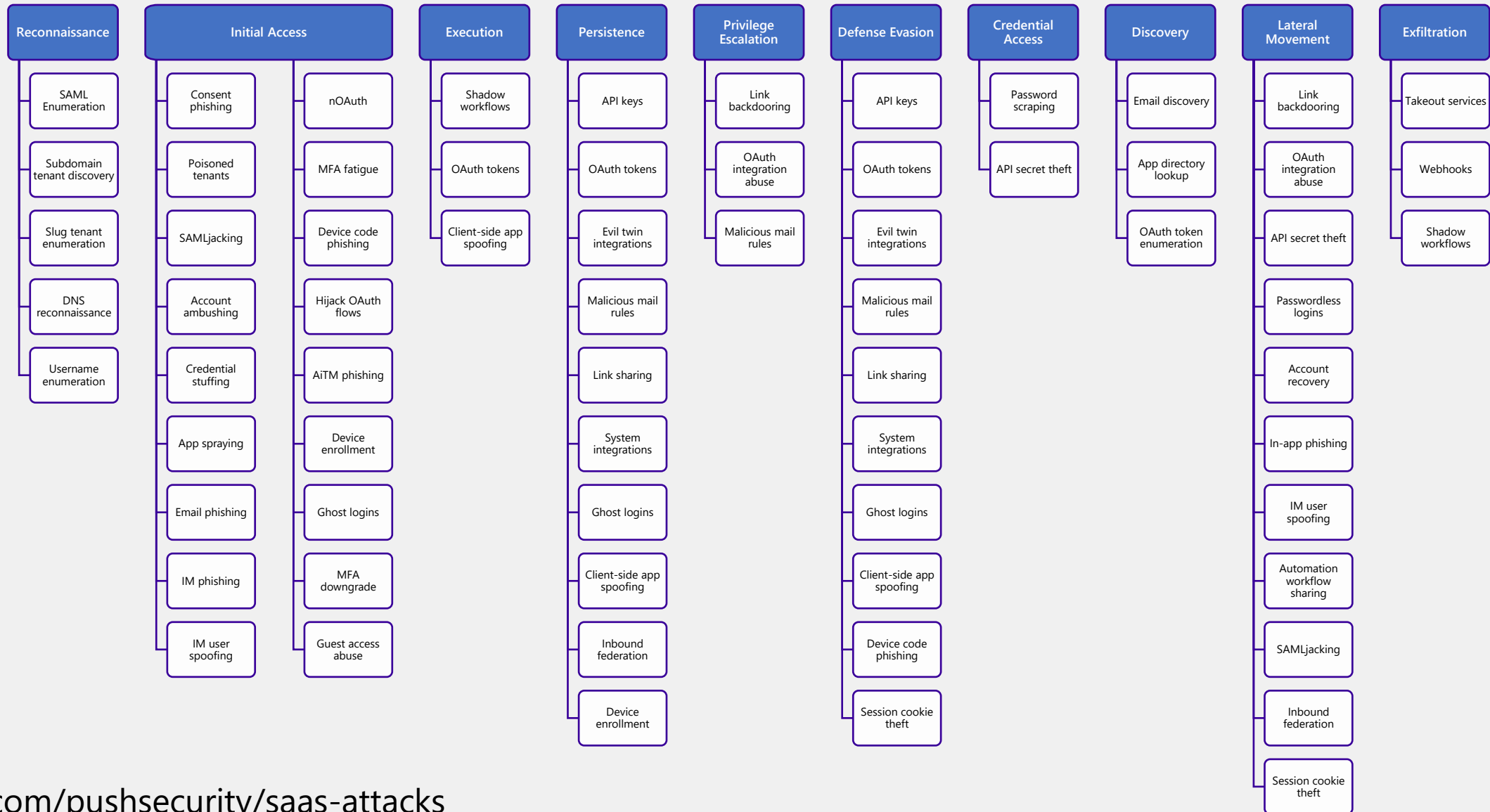
The problem

YOU SHALL NOT SAAS!





SaaS attacks matrix



Tenant administration abuses

ENTRA APPLICATION OWNER



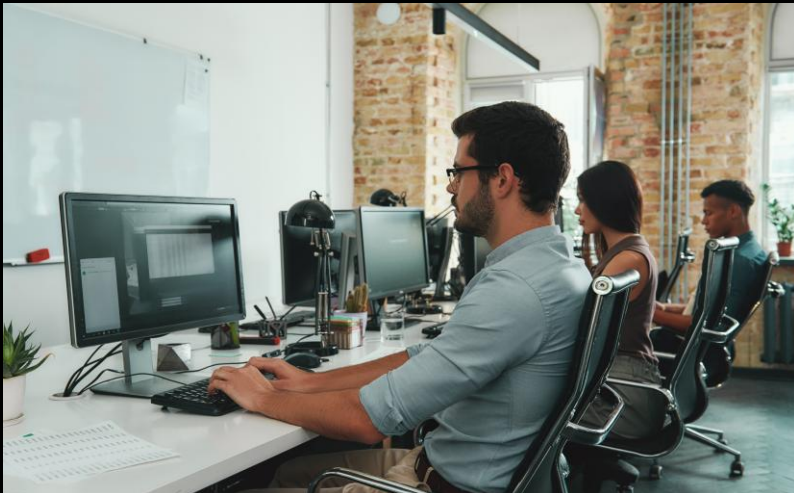
What my friends think I do



What my parents think I do



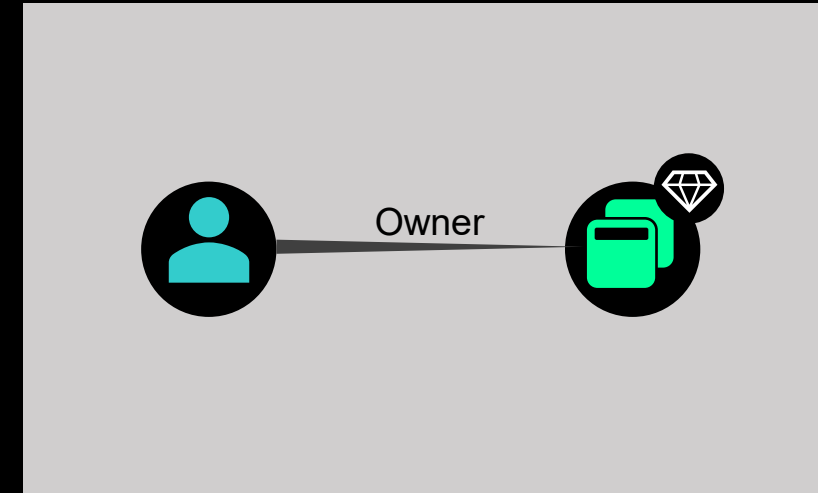
What Microsoft thinks I do



What the business thinks I do

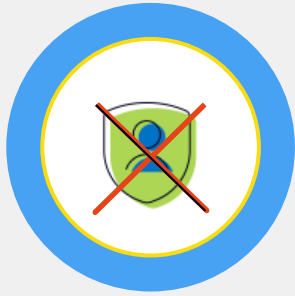


What I think I do

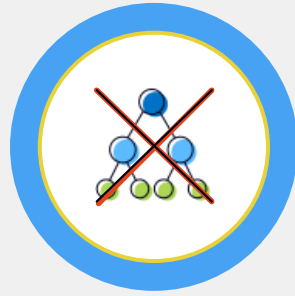


What I actually do

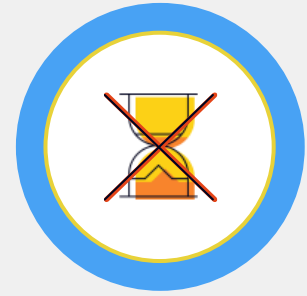
What's the problem with owners?



No Admin Protection

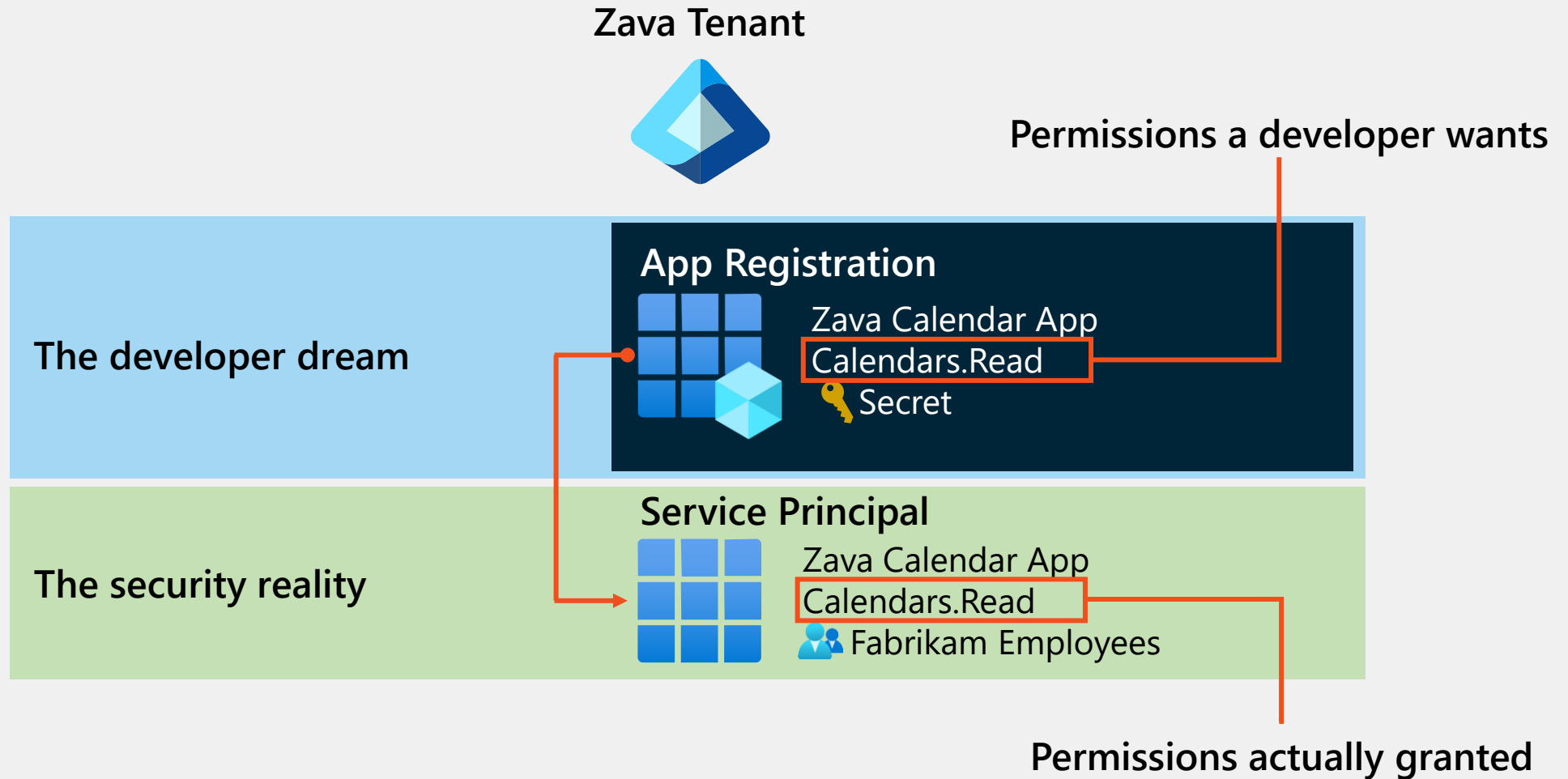


No granularity

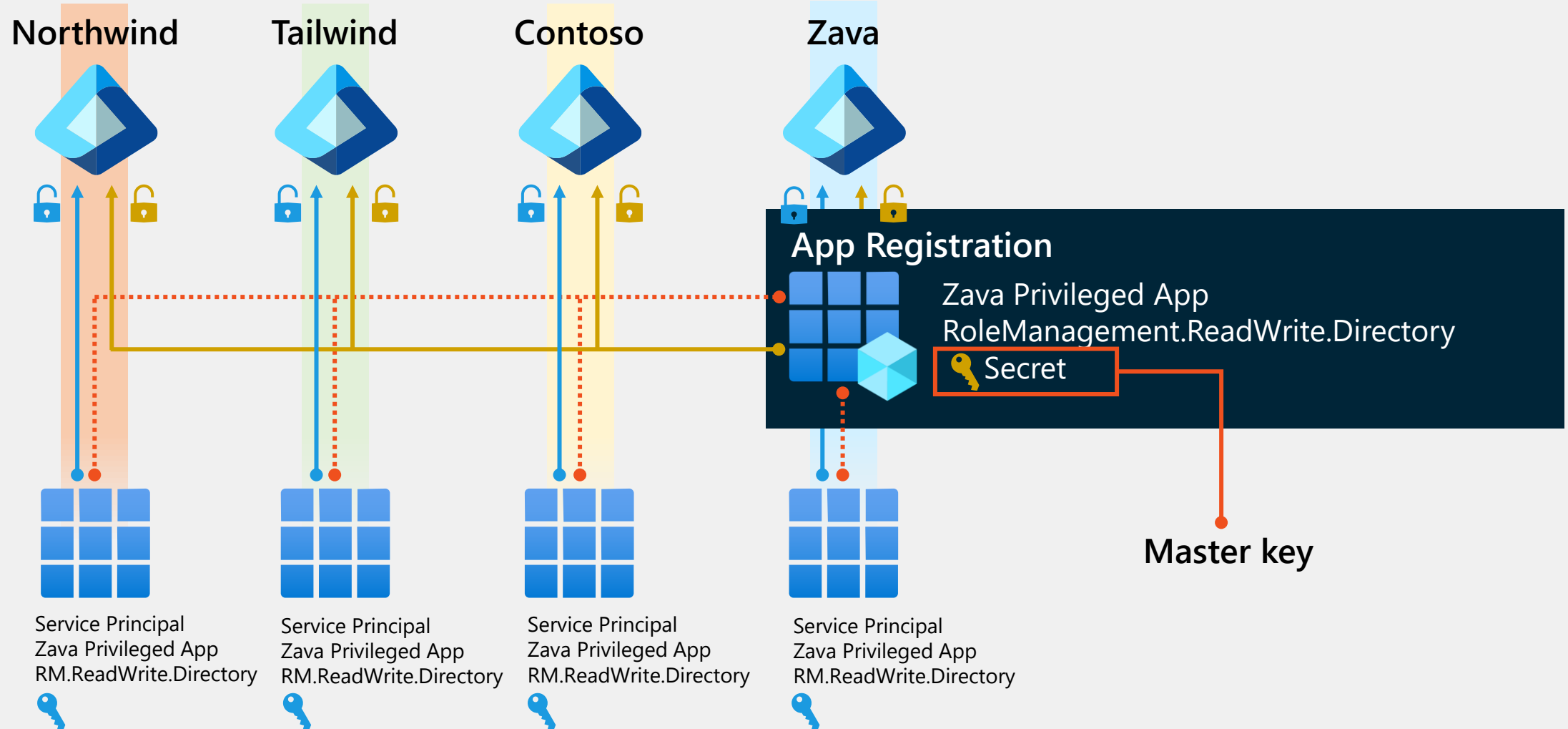


No just-in-time

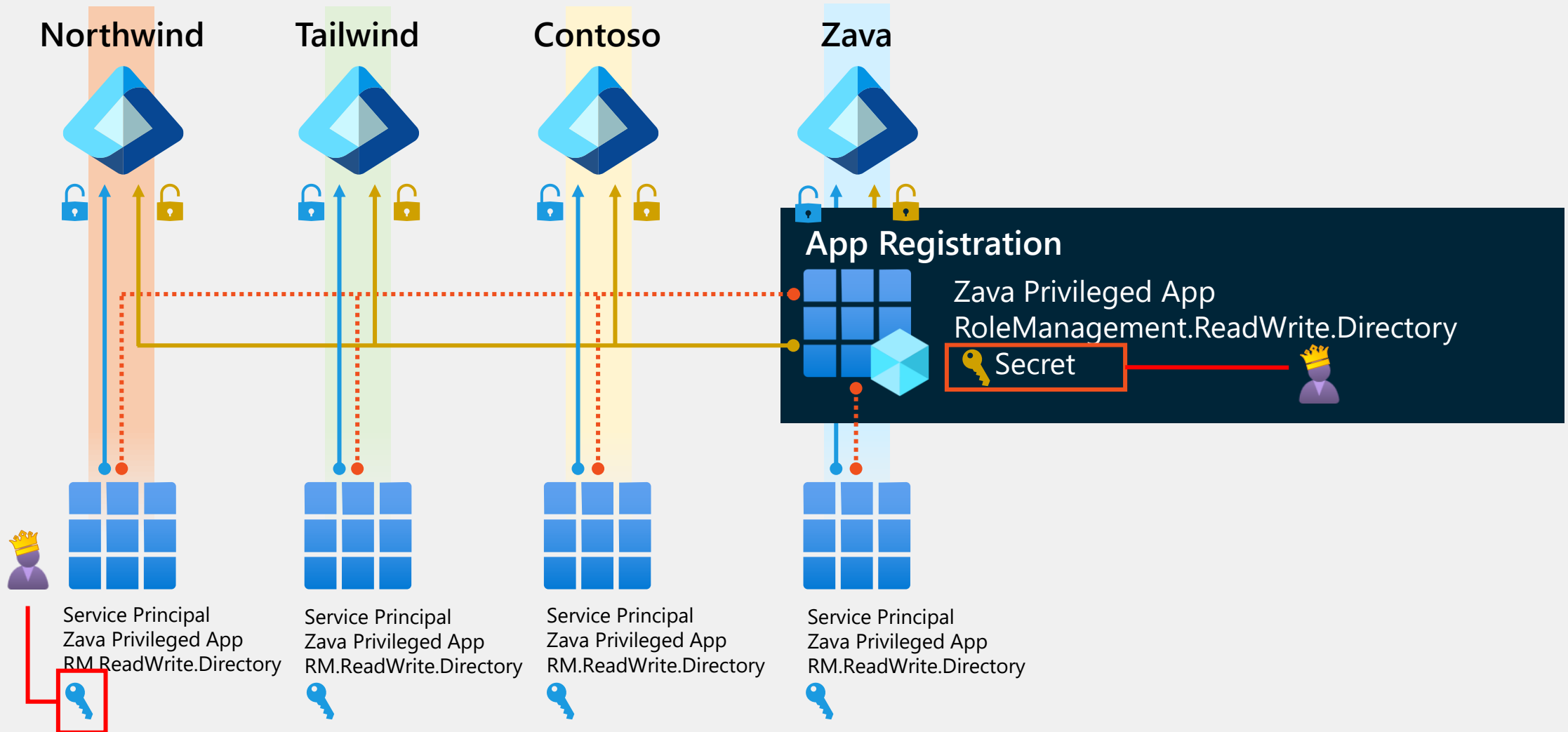
Service principals and app registrations



Multi-tenant application credentials

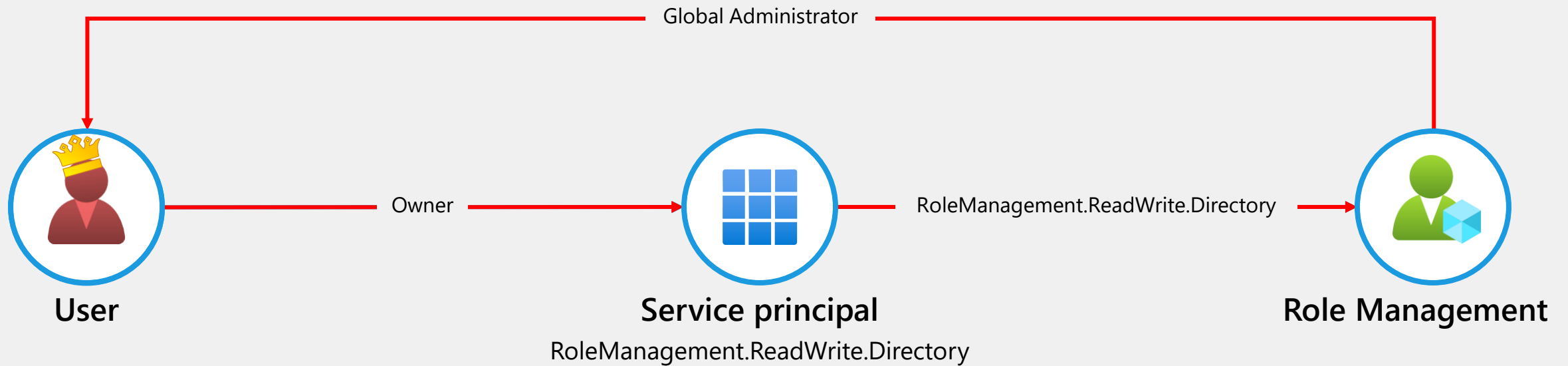


Multi-tenant application credentials

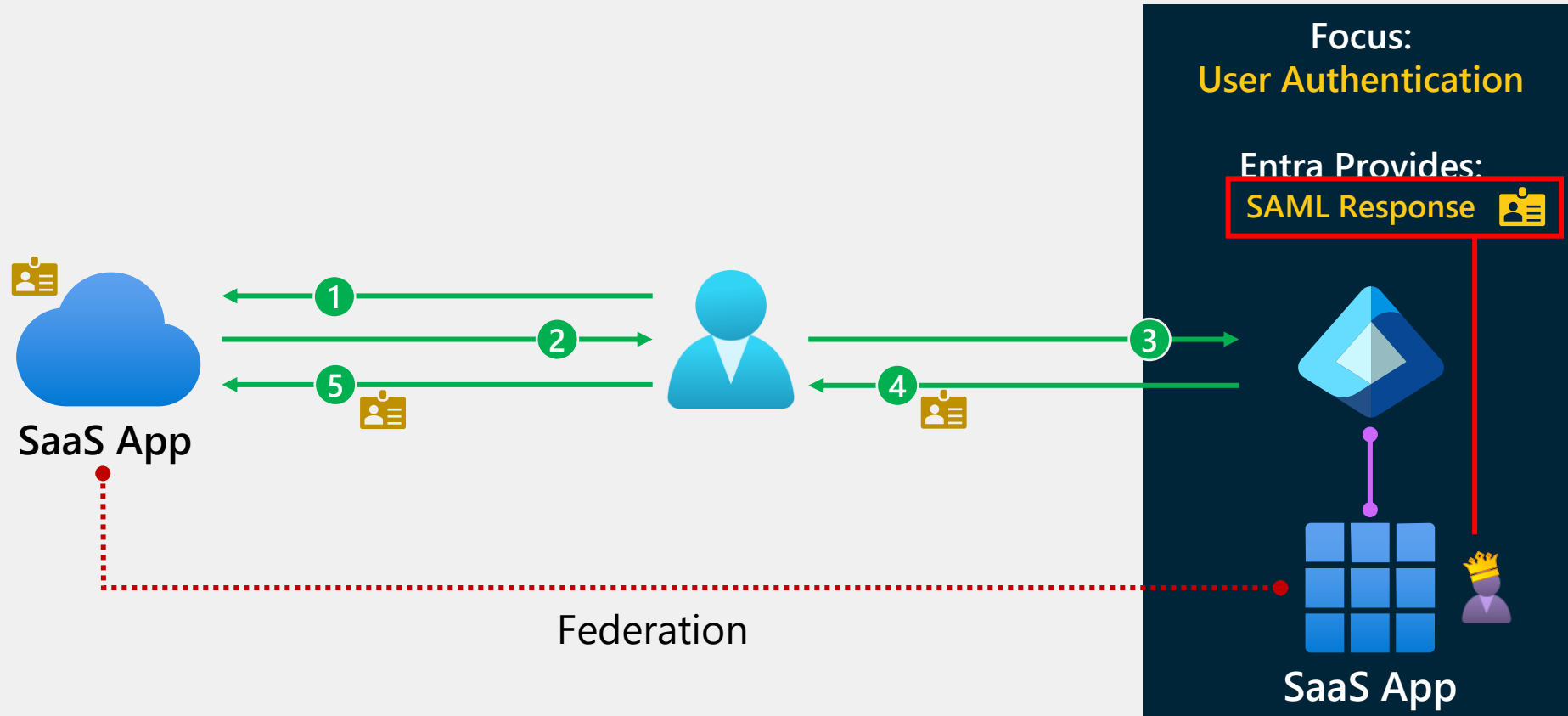


Abusing RoleManagement.ReadWrite.Directory

Abusing owner on privileged applications



SAML and federation



Abusing owner on SAML applications

servicenow

User name

Password

[Login with SSO](#) [Forgot Password ?](#)

Or log in with

Application owner defense



Owner



Service management reference attribute or Security Attributes
Cloud App Admin scoped to the App



**User
Accounts**



Admin accounts ideally with PAW and FIDO



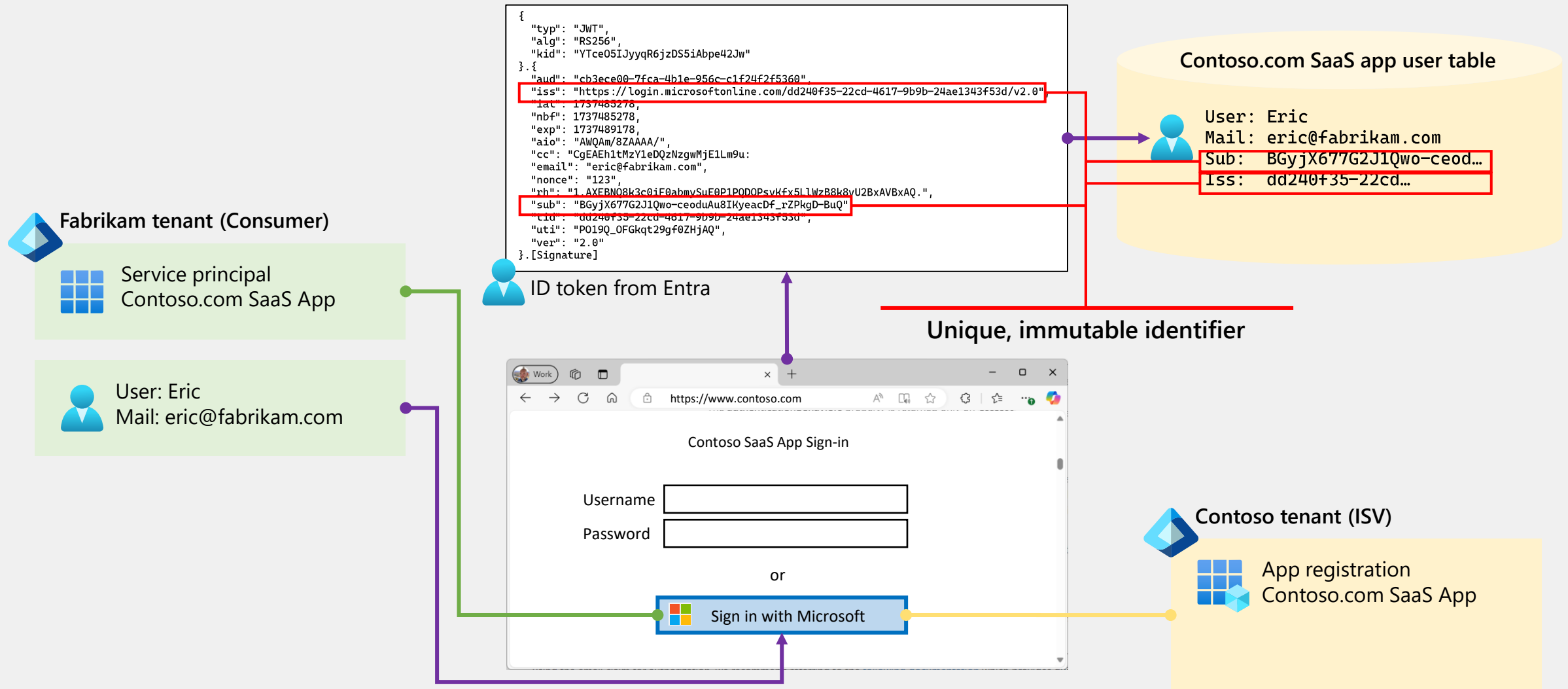
Perform regular and ongoing review of permissions

Developer derived abuses

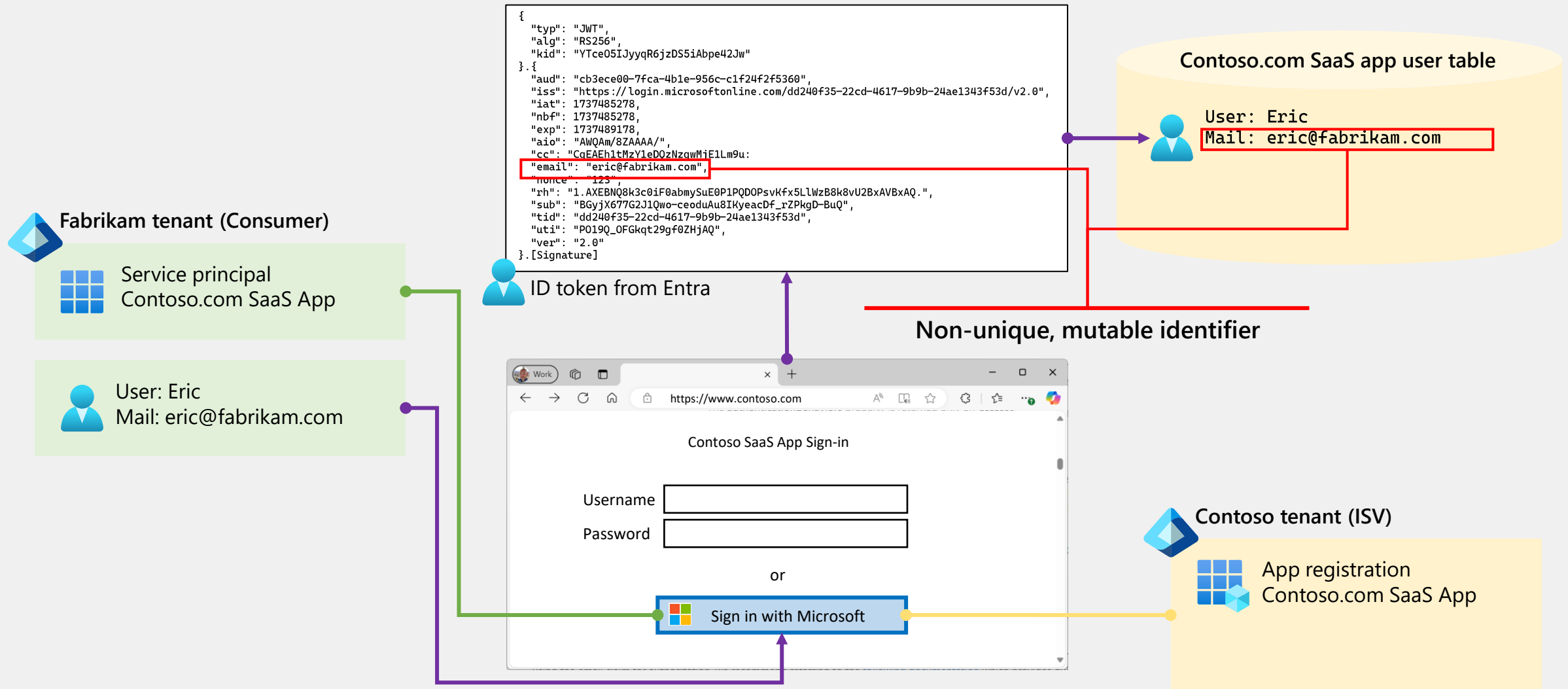
nOAuth

- First published by Descope June 2023
- nOAuth vulnerable applications do not properly implement OpenID Connect
- A cross-tenant type attack, the attacker only needs the email address of the victim
- Almost impossible to detect and defend against
- At its core is developers following anti-patterns with OIDC

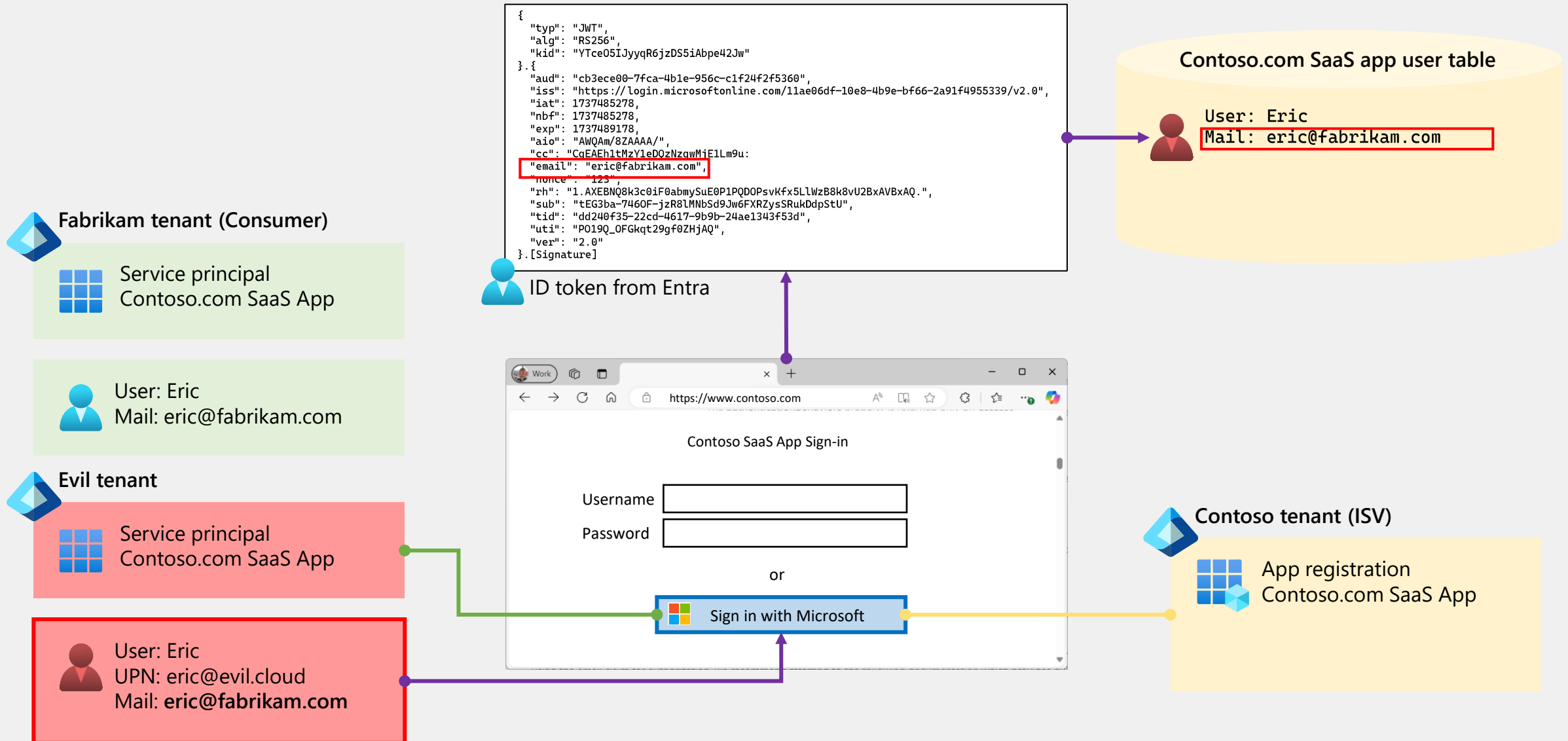
Following OpenID Connect standards



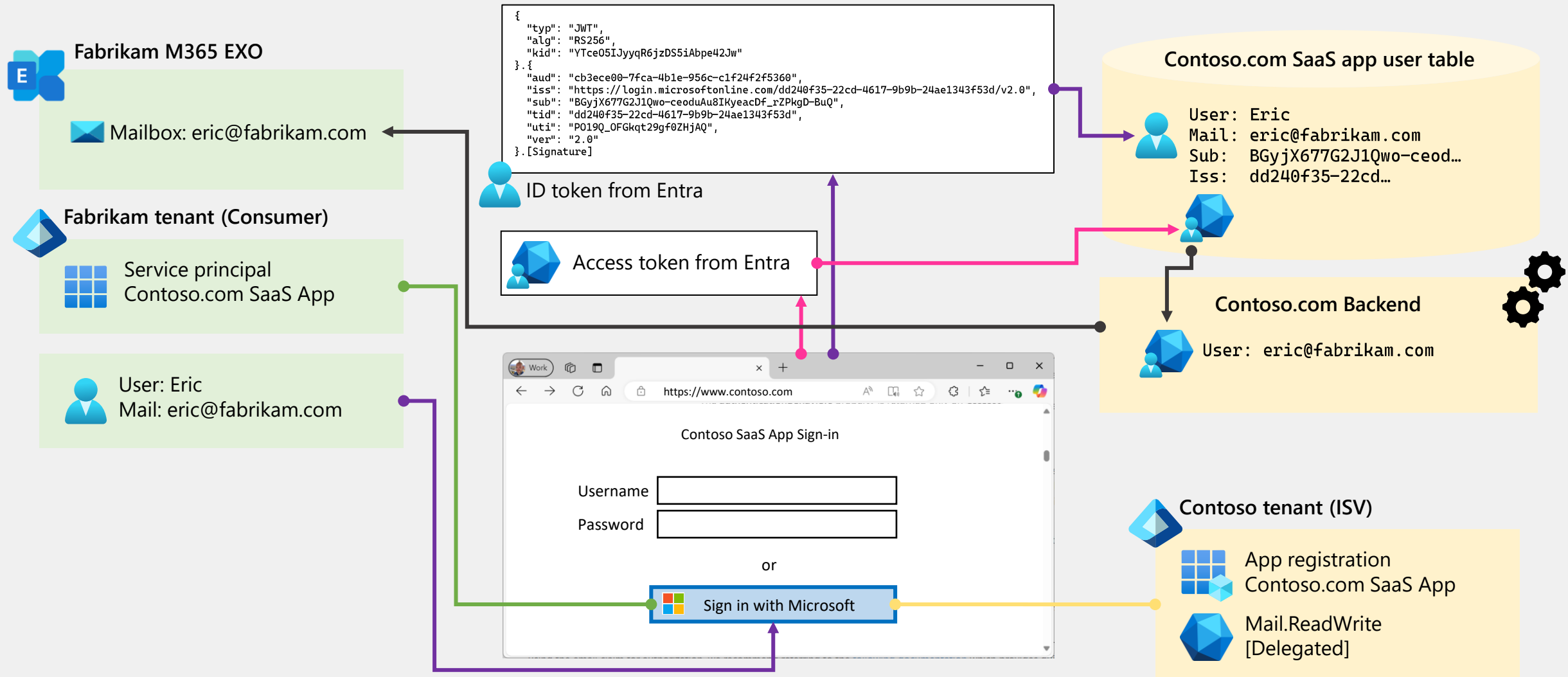
nOAuth vulnerable application



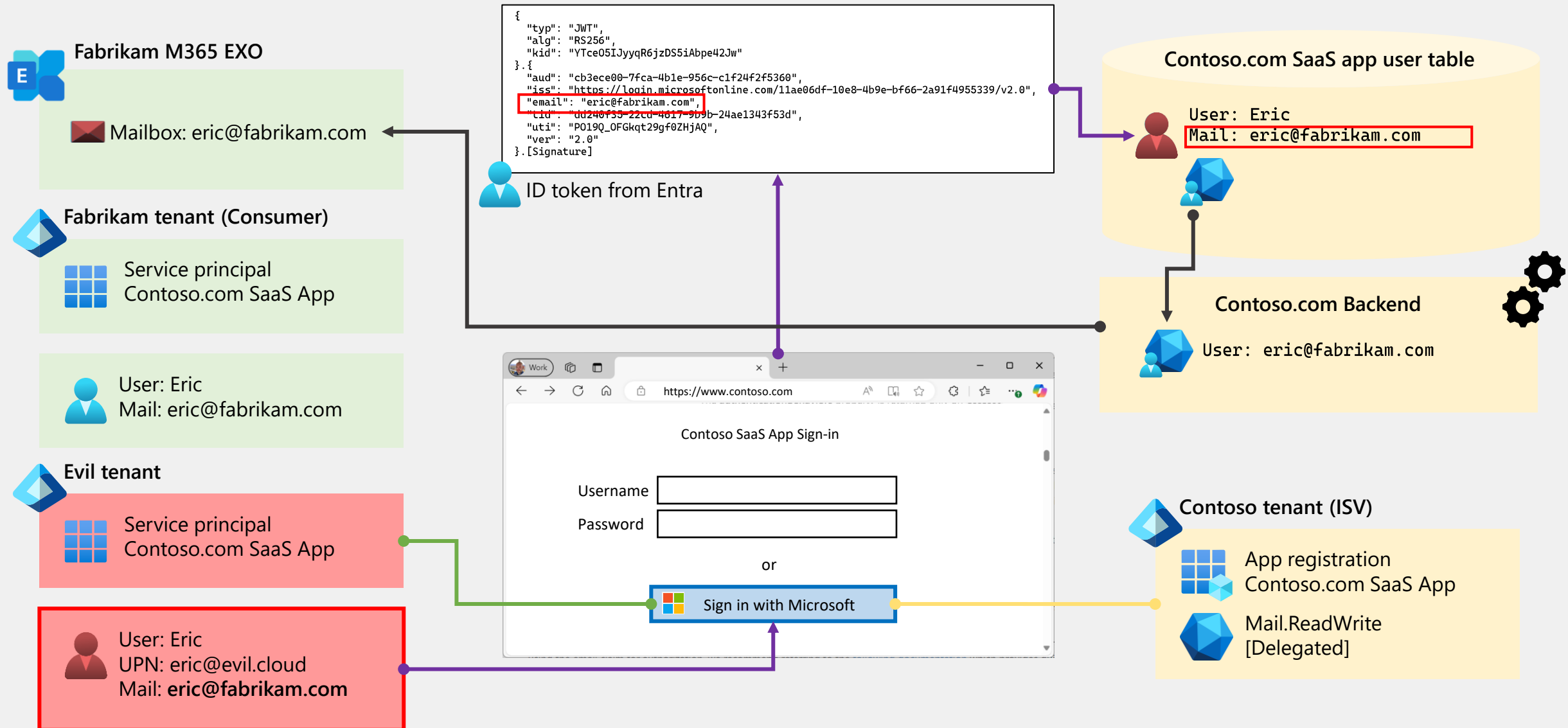
Abusing nOAuth



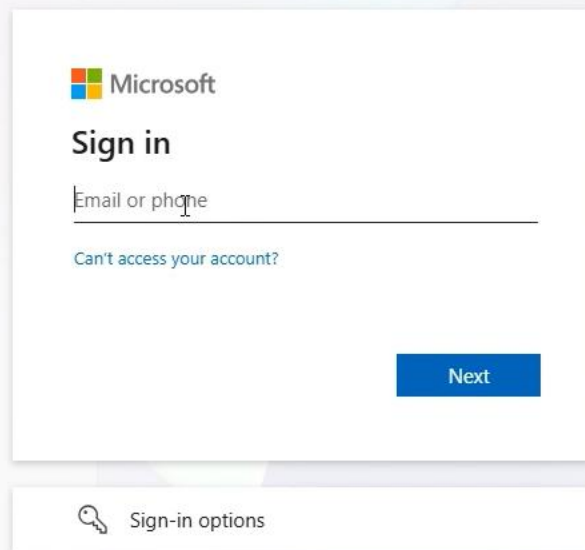
OpenID Connect and OAuth 2.0 in Entra ID



Abusing nOAuth to pivot back into Microsoft 365



noAuth abuse pivoting back into Microsoft 365



The image shows a Microsoft sign-in dialog box centered on a blurred background of a Microsoft 365 login page. The dialog box is white with a thin border and contains the Microsoft logo at the top left. Below the logo is the text "Sign in" in a bold, dark font. Underneath "Sign in" is a text input field with the placeholder text "Email or phone". Below the input field is a link that says "Can't access your account?". At the bottom right of the dialog box is a blue button with the text "Next". Below the dialog box is a white box with a magnifying glass icon and the text "Sign-in options".

Microsoft

Sign in

Email or phone

[Can't access your account?](#)

Next

Sign-in options

Defenses for developers



Use the integration assistant and follow the recommendations

Entra ID integration assistant

The screenshot displays the Microsoft Azure portal interface. At the top, the header shows 'Microsoft Azure' and a search bar. The breadcrumb navigation indicates the path: Home > CloudLab > BusinessApp-Auth-WebAPI. The main title of the page is 'BusinessApp-Auth-WebAPI | Integration assistant'. On the left, a sidebar contains various navigation options, with 'Integration assistant' currently selected. The main content area is titled 'Here's the integration assistant for BusinessApp-Auth-WebAPI' and includes a sub-header 'Application type : Desktop App, Web API' and 'Calls APIs : Yes'. Below this, there are tabs for 'Summary', 'Develop', 'Test', 'Release', and 'Monitor', with 'Summary' being the active tab. The 'Summary' tab displays two sections: 'Recommended configurations' and 'Discouraged configurations'. Each section contains a table with 'Item' and 'Status' columns. In the 'Recommended configurations' table, six items are listed, all with a status of 'Action required'. In the 'Discouraged configurations' table, one item is listed with a status of 'Complete'.

Microsoft Azure Search resources, services, and docs (G+ /)

Home > CloudLab > BusinessApp-Auth-WebAPI

BusinessApp-Auth-WebAPI | Integration assistant

Search (Ctrl+/) Refresh Got feedback?

Overview Quickstart Integration assistant

Manage

- Branding & properties
- Authentication
- Certificates & secrets
- Token configuration
- API permissions
- Expose an API
- App roles
- Owners
- Roles and administrators
- Manifest

Support + Troubleshooting

- Troubleshooting
- New support request

Here's the integration assistant for BusinessApp-Auth-WebAPI

Application type : Desktop App, Web API Edit

Calls APIs : Yes

Summary Develop Test Release Monitor

Recommended configurations

Item	Status
Configure a redirect URI for a desktop app by adding a platform.	Action required ***
Configure API permissions.	Action required ***
Configure a valid credential.	Action required ***
Configure a unique Application ID URI.	Action required ***
If expecting API requests on behalf of users, define scopes your API exposes.	Action required ***
If expecting API requests on behalf of apps directly, define app roles.	Action required ***
Assign users that should be able to view and edit this application registration as owners.	Complete ***

Discouraged configurations

Item	Status
If you are using the authorization code flow, disable the implicit grant settings.	Complete ***

Defenses for developers



Use the integration assistant and follow the recommendations



Take additional care with multi-tenant applications



Work with your developers to ensure they implement authentication properly

Vendor derived abuses

Multiple IdP support

Great for vendor
adoption

Not good for
security

SaaS apps and multiple IdPs



Sign in or create an account

Sign in

New user? [Create an account](#)

Email address

[Continue](#)

Or

 Continue with Google

 Continue with Facebook

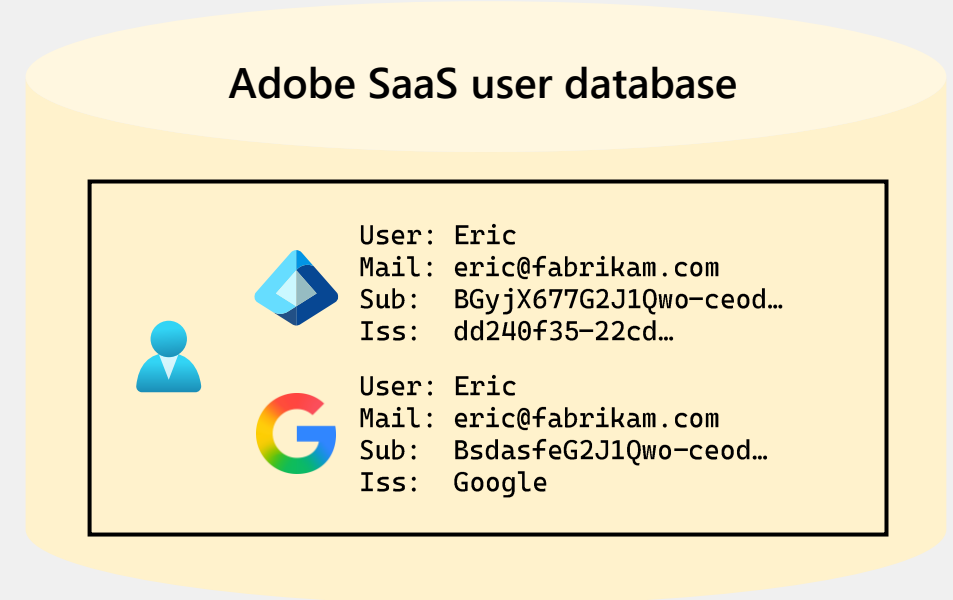
 Continue with Apple

 Continue with Microsoft

 Continue with LINE

 Continue with Kakao

[Get help signing in](#)



SaaS apps and multiple IdPs



Your verification code is:

912965

Your account can't be accessed
even if you didn't submit this request.

To keep your account secure,
password for your Adobe account.
Access app to sign in. Adobe's
authentication makes signing in
needing to remember or change

[Learn more](#) and download the



Your Apple account is now connected to your Adobe account
and may be used for sign in. You can disconnect it or add
another from your [Adobe Account](#).

If you did not request that these accounts be connected,
please [contact us immediately](#).

Thanks,
Adobe

Using Google to bypass Entra

AI readiness begins here

Create the context that people and AI agents need to understand your business. Get started with the Lucid Work Acceleration Platform.

Contact sales

Generate diagram



Create a process for an organization to adopt an LLM



Ready to see and build the future? We're ready to chat live.

Chat with sales live

Book time with sales

I need billing or support

Your chat is subject to our [Privacy Policy](#).



What did we just do?

➔ Bypass Entra

✗ Conditional Access

✗ Authentication Strength / MFA requirements

✗ Sign-in logs

✗ Defender for Cloud Apps integration

Enterprise defenses



Limit the ability to use additional identity providers

Can we stop this behavior in the app?

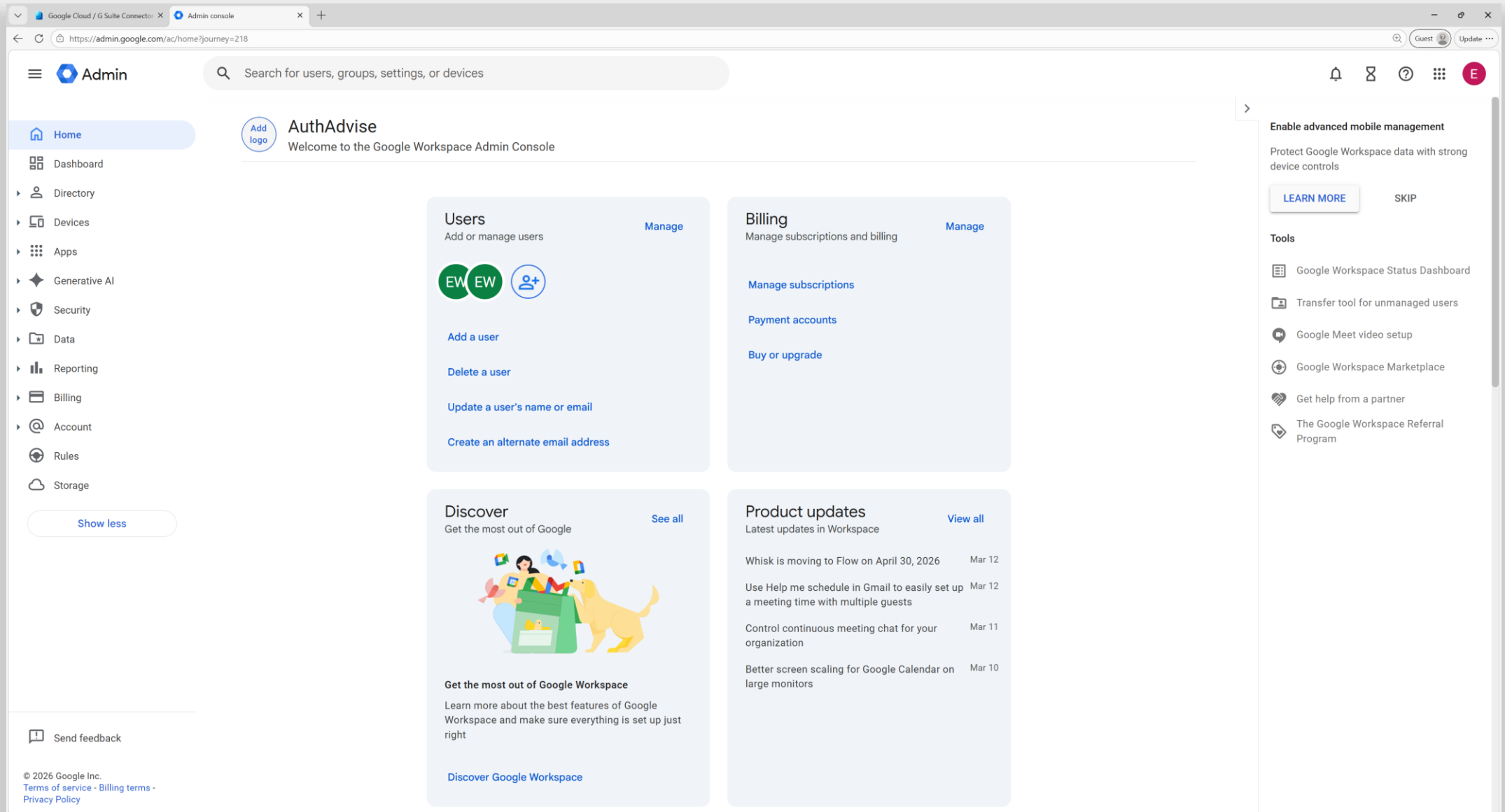
- It depends on the SaaS app
- Some SaaS apps support adjusting the supported IdPs
- Some have an SSO tax

Closing the Google gap



Acquire GCP or Google Workspace

Closing the Google gap



Closing the Google gap



Acquire GCP or Google Workspace



Configure SCIM to sync users to Google

Closing the Google gap

The screenshot displays the Microsoft Entra admin center interface. The left-hand navigation pane includes sections for Home, Entra agents, Favorites, Entra ID (with sub-items like Overview, Users, Groups, Devices, Agent ID, Enterprise apps, App registrations, Roles & admins, Delegated admin partners, Domain services, Conditional Access, Multifactor authentication, Identity Secure Score, Authentication methods, Account recovery, Password reset, Custom security attributes, Certificate authorities, and External Identities), and Troubleshoot.

The main content area is titled "Google Cloud / G Suite Connector by Microsoft | Overview". It features a top bar with action buttons: Start provisioning, Pause provisioning, Restart provisioning, Delete configuration, Refresh, and Got feedback. Below this is a blue informational banner stating: "This is a new version of the provisioning user experience. You can provide us feedback and suggestions on the new user experience using the 'Got feedback' button. [Click here to switch to the legacy experience.](#)"

The "Overview" tab is selected, showing a table of basic information:

Basic information	
Name	Google Cloud / G Suite Connector by Microsoft
Service principal object id	478bf01e-70d0-4a7b-a1d1-e0270fe696ee
Job ID	gsuite.5229e792743c48c6b1beaf77bb01e712.38aeb6...
Last cycle completed time	3/13/2026, 11:52:44 AM

Below the table, the "Current cycle status" is shown as "Incremental sync completed" with a progress bar at 100%. A link for "Provisioning details" is also present.

A section titled "USER" lists a single entry with the number "1".

At the bottom, the "Quick actions" section includes a button labeled "Provision on demand" with a user icon.

Closing the Google gap



Acquire GCP or Google Workspace



Configure SCIM to sync users to Google



Configure Google IAM to federate to Entra

Closing the Google gap

The screenshot displays the Google Admin console interface. The left sidebar contains navigation links: Home, Dashboard, Directory, Devices, Apps, Generative AI, Security (highlighted), Overview (selected), Alert center, Authentication (with sub-items: 2-step verification, Account recovery, Advanced Protection Program, Login challenges, Passwordless, Password management, SSO with SAML applications, SSO with third party IdP, Multi-party approval requests), Access and data control, Data, Reporting, and Billing.

The main content area is titled "Security > SSO with third-party IDPs > Manage SSO profile assignments". It features a search bar "Search for users, groups, settings, or devices" and a "REMOVE SCOPE" link.

The central panel is titled "Single sign-on (SSO) with third-party identity providers (IDPs)". It includes a search bar "Search for organizational units" and a list of organizational units: "AuthAdvise" (selected) and "Admins".

The right panel, titled "Manage SSO profile assignments", shows settings for users in "AuthAdvise". It includes a section "SSO profile assignment" with the text "Applied at 'AuthAdvise'" and a dropdown menu "Select SSO profile" currently set to "Microsoft - OIDC". A note states: "Most changes take effect in a few minutes. [Learn more](#). You can view prior changes in the [Audit log](#)". At the bottom are "CANCEL" and "SAVE" buttons.

With Google redirecting to Entra ID

AI readiness begins here

Create the context that people and AI
agents need to understand your business.
Get started with the Lucid Work
Acceleration Platform.

Contact sales

Generate diagram



Create a process for an organization to adopt
an LLM

Blog article coming soon on Google bypass



@ericonidentity.com



@ericonidentity



/in/ericonidentity



@ericonidentity@infosec.exchange

But note...

- Some SaaS apps still support local authentication

Using local authentication to bypass Entra

Log In

AuthAdvise

Your email address

Enter password

[Forgot your password?](#)

Log in →

Or Sign in with



Google



Microsoft

If you have an @authadvise.com email, you can

[Sign Up to AuthAdvise's account](#)

[Login to another account](#)

[Can't log in? Visit our help center](#)

Chat

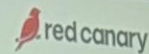


Search



4:51 PM
3/13/2026

Axioms



1. You can't **detect** what you don't **see**.

Detection



LOL almost impossible

Entra Sign-in	Time
	2025-06-11T15:03
eric@fabrikam.cloud	2025-06-11T15:04
melissa@fabrikam.cloud	2025-06-11T16:30
melissa@fabrikam.cloud	2025-06-11T16:30



Enterprise defenses



Limit the ability to use additional identity providers



Explore options for browser level identity security



Investigate SaaS Security Posture Management (SSPM) platforms



SIEM and/or CASB integration whenever feasible

Wrap up

Red team takeaways



There is much more to explore than just Entra, Azure, and M365



Identity security with SaaS applications is still under-researched



Attack path analysis tools won't necessarily find these gaps

Blue team takeaways



Think defense in depth across the stack: Users + Entra + Applications



Monitor across the stack: ITDR + Browser monitoring + SSPM



It's not realistic for corporate IT or SecOps to check for all abuses

Thank you!



Eric Woodruff



Chief Identity Architect
Microsoft Security MVP
IDPro Certified Identity Professional (CIDPRO)



@ericonidentity.com



@ericonidentity



/in/ericonidentity



@ericonidentity@infosec.exchange